

MAX 26.21.1 V2 — Аудит безопасности и обзор изменений (база сравнения: 26.21.1 V1)

Объект: `ru.oneme.app` (основной) / `ru.oneme.ap2` (клон), `versionName` **26.21.1**, стоковый build 6761 **Релиз:** MAX 26.21.1 GP V2 — Mods by JohNick (arm64-v8a + armeabi-v7a, основной + клон, 4 APK) **Дата:** 2026-07-06 **Метод:** статический анализ — baksmali (smali всех 3 dex), AndroidManifest, `network_security_config`, ресурсы; сборка через pipeline `make_v1` с регрессией pytest и smoke-тестом на устройстве (Samsung S25, Android 15). **База движка:** TamTam (`ru.ok.tamtam`) + VK Calls SDK (WebRTC). Обфускация R8. **База сравнения:** предыдущая опубликованная версия мода — **26.21.1 GP V1**.

> Назначение документа: зафиксировать, что нового и что изменилось относительно 26.21.1 V1. Ключевое в V2 — **расширенная приватность на транспортном уровне** (глушение опкода 5 WS-пайплайна + write-side гейт `pmsMap` для TLS/DoH серверных рубильников) + **новый тумблер** `hideUsefulNotifs` (скрытие промо-чата «Полезные уведомления») + **система-aware тема диалога флагов**.

ЧАСТЬ 1. Что нового относительно 26.21.1 V1

1.1 Платформа

Мод собран на том же стоке **MAX 26.21.1 (build 6761)**, R8-карта не менялась, `VersionName` сохранён. Все нейтрализации и функции V1 остаются без потерь. Дельта V2 — три сетевых нейтрализации + один новый пользовательский тумблер + UX-полировка.

1.2 Приватность транспорта — write-side гейт `pmsMap` (TLS + DoH)

Проблема. Сервер MAX доставляет клиенту рантайм-конфигурацию `pmsMap` через WS-команду `NOTIF_CONFIG` (опкод 134) — это ~378 булевых/строковых рубильников (`PmsProperty`), включая **потенциально опасные сетевые ключи**:

- `net-ssl-session-validate` (default: true) — при активации сервером в false отключает TLS-валидацию сессии → возможен MITM WS-канала и медиа-загрузок.
- `net-client-dns-enabled` (default: false) — при активации сервером в true включает клиентский DoH-резолвер через сторонний upstream → обход DNS-sinkhole на маршрутизаторе/провайдере.

Стоковые дефолты безопасны, но серверная активация опасного значения происходит без участия пользователя и без обновления клиента.

Решение — MINIMAL-2 write-side гейт. В точке парсинга `NOTIF_CONFIG` (метод `c2/lqk.smali::d(Lw2a;)Ljava/util/Map;`) перед `Map.put(key, value)` вставлен фильтр: для двух перечисленных ключей значение серверного значения **игнорируется** и заменяется на безопасную константу.

- `net-ssl-session-validate` → форсируется `Boolean.TRUE` (TLS-валидация всегда включена).
- `net-client-dns-enabled` → форсируется `Boolean.FALSE` (клиентский DoH заблокирован).

Sentinel: # `:pms_blacklist_gate`. Скрипт: `apply_v_pms_neutralize.py`.

Свойства:

- Точечный фильтр (2 ключа из ~378) — легитимные рубильники (`experiments`, `forceUpdateVersion`) не затронуты.
- Гейт срабатывает в парсере, до попадания значения в реестр — read-side геттеры получают безопасное значение автоматически.
- Тумблера нет (базовая приватность, всегда включена).

1.3 Приватность транспорта — глушение WS-команды опкод 5

Проблема. WS-пайплайн MAX содержит опкод 5 — служебный канал сериализации трафика на клиенте (внутренний LOG). При включённой серверной команде значение публикуется в `AppMetrica/OneME`-каналы, вне зависимости от того, что `MyTracker` уже нейтрализован в предыдущих версиях.

Решение. В обработчик команд `c1/zwa.smali::j(Lm5h;ZJLw4h;)V` в самом начале метода вставлено короткое замыкание: если `command.opcode() == 5` → `return-void` без обработки. Портировано из независимой сборки Geen MAX 26.20.2 (метод `zua.j`), поведение выверено на живом клиенте.

Sentinel: # :gate_opcode5_dead_zone. Скрипт: `apply_v_gate_opcode5.py`.

Свойства:

- Глушится ровно опкод 5, остальные WS-команды обрабатываются штатно.
- Изменение не влияет на handshake, аутентификацию, доставку сообщений или звонки.
- Тумблера нет (базовая приватность).

1.4 Приватность транспорта — реактивация WS redirectHost MITM-guard

В стоковой сборке 26.21.1 обработчик WS `c3/de6.smali` (парсер команды `SESSION_INIT`) применяет серверные значения `host/port/tls` от сервера — это позволяет серверу принудительно перевести клиента на альтернативный WS-узел (в норме — балансировка; в атаке — редирект на MITM-прокси).

В V1 соответствующий гейт (`apply_v_p0_3_ws_yf.py`) числился в реестре пайплайна как STALE (комментарий эпохи 26.20.2). Перепроверка якорей в 26.21.1 показала, что метки-цели `:cond_c7`, `:goto_c7`, `:cond_10e` присутствуют в `de6.smali` — гейт применим без изменений. Скрипт реактивирован в V2.

Sentinel: # :redirect_host_guard. Скрипт: `apply_v_p0_3_ws_yf.py`.

Свойства:

- WS-редирект от сервера игнорируется, клиент остаётся на первоначальном хосте, полученном из статической конфигурации.
- Штатная балансировка нагрузки на серверной стороне не критична для мессенджера — WS-соединение долгоживущее.
- Тумблера нет.

1.5 Тумблер #16 — «Скрыть чат "Полезные уведомления"»

Добавлен пользовательский переключатель `hideUsefulNotifs`. Скрывает верифицированный промо-чат «Полезные уведомления» из списка `recent-chats` — по подстроке в `title` (сервер эмитит имя как строку, ресурсной константы нет).

Точка фильтра — тот же `chokerpoint Lu00.b(List, Runnable)V`, который используется для скрытия «Избранное»/«MAX»/«Коды подтверждения». Реализовано как ветвь в `filterChatList`.

Категория UI: «Сервисные чаты» (вместе с `hideVerifyCodes`, `hideMaxOfficial`, `hideInteresting`).

1.6 UX — тема диалога флагов следует системной

В V1 диалог «Настройки MAX» (скрытый long-press по номеру версии) отображался в светлой теме независимо от системной. На устройствах с включённой тёмной темой это выглядело как белое всплывающее окно поверх тёмного фона.

В V2 диалог и все его подменю (категории + под-диалоги групп) инициализируются с `AlertDialog.Builder(Context, themeResId)`, где `themeResId` выбирается по `Configuration.uiMode & 0x30`:

- Системная тёмная (0x20) → `Landroid/R$style;->Theme_DeviceDefault_Dialog_Alert`.
- Системная светлая → `Landroid/R$style;->Theme_DeviceDefault_Light_Dialog_Alert`.

Правится в генераторе `gen_appflags.py` — все точки инъекции диалогов (`showCategoryMenu`, `showCat0..N`) получают идентичный `theme-picker`.

Как открыть меню флагов: long-press или короткий tap по номеру версии в настройках MAX — оба жеста работают.

1.7 Известные ограничения (не покрыто в 26.21.1 V2)

- «Отметить непрочитанным» в режиме Невидимка (antiRead ON). Ручная пометка чата непрочитанным через контекстное меню откатывается серверным sync-путём (WRITE-side Lgzh; ->a(...)). Исправление требует отдельного per-chat реестра {chatId: timestamp} — архитектурная работа, вынесена на будущий релиз.
- Персист device_id клона при полном pm clear. Клон ru.oneme.ap2 при полной очистке данных теряет device_id для push-регистрации — пользователю потребуется повторный вход по SMS. При штатном install -r (обновление поверх) device_id сохраняется.

1.8 Метрики

- 16 пользовательских переключателей (+1 к V1: hideUsefulNotifs).
- Регрессия: pytest прошла на уровне V1.
- verify критических слоёв — 0 FATAL; smali-сборка 3 DEX без VerifyError; 4 APK подписаны (apksigner v2+v3, без v1).
- Smoke на устройстве — PASS (main + clone запускаются без FATAL/VerifyError/IncompatibleClass; функциональная проверка — TLS-сессии установлены штатно, чаты открываются, звонки работают, тема диалога следует системной).

ЧАСТЬ 2. Полный перечень функций (16 переключателей + жест + always-on)

#	Переключатель	Что делает
1	Антиудаление	Удалённые собеседником сообщения остаются с пометкой «удалено»
2	Невидимка	Скрывает набор текста, прочтение и онлайн (typing/read/presence) + режим «Призрак»
3	Скрыть папку «Всё»	Убирает вкладку-папку «Всё» в списке чатов
4	Скрыть папку «Сферум»	Убирает вкладку «Сферум» + пункт «Войти в Сферум» в настройках
5	Скрыть папку «Избранное»	Убирает вкладку-папку и сам чат «Избранное»
6	Скрыть «MAX для бизнеса»	Убирает рекламную карточку в настройках
7	Скрыть «Пригласить друзей»	Убирает пункт «Пригласить друзей» в настройках
8	Чаты на первом месте	Меняет порядок нижних вкладок
9	При открытии — папка «Новые»	Стартовая папка при запуске — «Новые»
10	Автозапуск MAX	Управляет автозапуском после перезагрузки
11	Улучшить уведомления	WS-reconnect при смене сети; исключение из оптимизации батареи
12	Основная камера для кружков	Видео-кружки начинаются с основной камеры
13	Debug-меню звонков	Разблокирует скрытое debug-меню в звонках
14	Скрыть номер телефона от оператора	Блокирует Header Enrichment / Mobile ID запрос
15	Скрыть номер телефона в профиле	Прячет строку с номером в профиле
16	Скрыть чат «Полезные уведомления» (V2)	Скрывает верифицированный промо-чат из списка
—	Скрыть чат «Коды подтверждения»	(тумблер hideVerifyCodes из категории «Сервисные чаты»)
—	Скрыть чат «MAX»	(тумблер hideMaxOfficial, покрывает все 8 омоглиф-комбинаций)

Скрытый жест — long-press или короткий tap по номеру версии → диалог «Настройки MAX» (тема следует системной).

Always-on приватность (без тумблеров): снятие FLAG_SECURE (скриншоты разрешены), no-IP telemetry (IP-адрес вырезан из отправляемых событий), auto-rotate экрана, AppLink prompt once-guard.

ЧАСТЬ 3. Нейтрализованные угрозы

К 13 угрозам из аудита 26.21.1 V1 добавляются **3 транспортных**:

- **T1 (V2):** серверный push отключения TLS-валидации через `pmsMap["net-ssl-session-validate"]` → форс `TRUE` в парсере.
- **T2 (V2):** серверный push клиентского DoH через `pmsMap["net-client-dns-enabled"]` → форс `FALSE` в парсере.
- **T3 (V2):** серверный push WS-редиректа на альтернативный узел через `SESSION_INIT.host/port/tls` → игнорируется в `de6.smali` парсере.
- **T4 (V2):** серверный WS-опкод 5 (внутренний LOG-канал сериализации) → короткое замыкание в `zwa.j`.

Итого: **17 нейтрализаций (13 из V1 + 4 новых)**. Стоковый build 6761 не изменился — новых угроз в стоке не появилось.

ЧАСТЬ 4. Сборка, подпись, верификация

- **versionName:** 26.21.1; versionCode форсирован в максимум.
- **Пакеты:** `ru.oneme.app` (основной), `ru.oneme.ap2` (клон).
- **Подпись:** apksigner Google scheme v2+v3 (без v1); cert SHA-1 `d6a7d757...298b` — общий со всеми сборками 26.x, что позволяет `install -r` поверх предыдущих версий без удаления данных.
- `resources.arsc` хранится без сжатия (STORED) — требование Android R+.
- `libtracernative.so` физически удалён из APK.
- **Пайплайн:** декларативный реестр шагов; каждая точка сверена по содержимому. В V2 добавлены `apply_v_gate_opcode5.py` и `apply_v_pms_neutralize.py`; реактивирован `apply_v_p0_3_ws_yf.py` (проверены якоря в 26.21.1 `de6.smali`).

SHA-256 финальных APK

```
abad55a615a34f569713566e588e18dadf6a95fe36d1157d519656cb0a47c371 MAX_26.21.1_arm64_V2.apk
4b4ed173925e14c457e6c903a14eeaec8077d15c966e95d1e9599fa41f29f019 MAX_26.21.1_arm64_V2_clone.apk
aebf9439d457c7d21cd070f6d1142b86bf0a1c24cbdfaaddb58bf0754d719048 MAX_26.21.1_arm7_V2.apk
b55a0f5a2df7fb3cba504667de3510869f0cea31a8b10363199aa4de997386cd MAX_26.21.1_arm7_V2_clone.apk
```

Документ описывает учебно-исследовательскую модификацию для личного использования. Автор: Mods by JohnNick.